

TIB SYSTEMS LLC

SAP Security, GRC & Controls — Training Division

The SAP Application Landscape

for Controls, Auditing & SOX/ITGC Consulting

Prepared for: Incoming Trainees / No Prior SAP Application Landscape Experience

Document Code: TIB-TRN-PREREQ-SAP-APPS-LANDSCAPE-003

Course Track: Companion to TIB-TRN-PREREQ-SAP-FOUNDATIONS-001 and TIB-TRN-PREREQ-SAP-SECURITY-CONTROLS-002

Version: 1.0

Issued: August 2026

WHO THIS GUIDE IS FOR

The first two guides in this series taught you how SAP works and how SAP Security and Controls work inside one system. In real engagements, though, “SAP” is never just one system — it is a landscape of connected applications: the core ERP, one or more GRC tools, a modern web front end, a cloud platform underneath it, and a surrounding ring of identity, monitoring, and third-party tools. This guide is your map of that landscape — what each piece is, how it protects itself, and what it means for the controls work you will be doing.

How to Use This Guide

Every application in this guide follows the same three-question pattern, deliberately, so you can compare them quickly: What is it? How is access to it actually protected? And what does that mean for the controls work you will do around it? Once you can answer those three questions for one application, you effectively already know how to ask them about the next one — the pattern repeats far more than the vocabulary changes.

What This Guide Covers

1. Chapter 1 — A map of the whole landscape before we zoom into any one piece.
2. Chapter 2 — SAP S/4HANA, the core ERP system everything else revolves around.
3. Chapter 3 — The SAP GRC suite — the tools built specifically to manage and monitor controls.
4. Chapter 4 — SAP Fiori, the modern web front end.
5. Chapter 5 — SAP BTP, the cloud platform underneath modern SAP, and the identity services that live on it.
6. Chapter 6 — Cloud security fundamentals that apply no matter which cloud application you're looking at.
7. Chapter 7 — The rest of the ecosystem: other SAP applications and the third-party tools you will regularly meet alongside them.
8. Chapter 8 — How all of it fits together, end to end, in one continuous story.
9. Chapters 9–10 — Glossary and readiness checklist.

Chapter 1 — Mapping the Landscape

Before zooming into any single application, it helps to see the whole board. A modern SAP customer landscape is rarely one system — it is a set of connected layers, some running in the customer's own data center, some running entirely in SAP's cloud, and some running on infrastructure the customer barely thinks about at all.

Layer	Category	Where It Runs	Why It Matters for Controls
SAP S/4HANA	Core ERP	On-Premise, Private Cloud, or Public Cloud	Runs the actual business transactions — finance, procurement, sales — and enforces authorization checks on every one of them.
SAP GRC Suite / Cloud IAG	Controls Management	On-Premise (GRC) or Cloud (IAG)	Manages access risk, access requests, emergency access, and automated control monitoring across the rest of the landscape.
SAP Fiori	User Interface	Runs on top of S/4HANA / BTP	The screen most users now interact with — tile-based, browser-friendly, but governed by the same authorization model underneath.
SAP BTP	Cloud Platform	Cloud	Hosts extensions, integrations, analytics, and the identity services that broker logins across the whole landscape.
SAP Cloud Identity Services	Identity / SSO	Cloud (runs on BTP)	Authenticates users once and provisions/deprovisions their access across every connected system.
Other SAP Cloud Apps (SuccessFactors, Ariba, Concur, Analytics Cloud)	Line-of-Business SaaS	Cloud	Each runs its own access model, but often feeds or depends on identity and provisioning decisions made elsewhere in the landscape.
Solution Manager / Focused Run	Technical Operations	On-Premise / Cloud	Monitors system health and governs the change/transport pipeline between development, test, and production.

Layer	Category	Where It Runs	Why It Matters for Controls
Third-Party Tools (identity providers, ITSM, specialized GRC/security tools)	Surrounding Ecosystem	Varies	Frequently sit alongside SAP's own tools, especially for single sign-on, ticketing, and deeper technical security scanning.
KEY IDEA Every one of these applications answers the same three questions this guide keeps asking: what is it, how does it protect itself, and what does that mean for controls. Once that pattern is familiar, an unfamiliar application in a real engagement stops being intimidating — it's just the same three questions with a new name attached.			

Chapter 2 — SAP S/4HANA

What It Is

SAP S/4HANA is SAP's current-generation core ERP suite — the successor to the older SAP ECC system — built to run on SAP's own in-memory database, HANA. It is where the actual business happens: general ledger postings, purchase orders, sales orders, inventory movements, payroll interfaces. Everything covered in the Foundations Primer — the client/application server/database architecture, T-codes, ABAP — describes how S/4HANA itself works under the hood. S/4HANA comes in more than one deployment flavor: On-Premise (the customer runs and manages the infrastructure), Private Cloud Edition (SAP or a partner hosts and manages the infrastructure, but the customer still controls configuration and change timing much like on-premise), and Public Cloud Edition (a fully standardized, SAP-managed, multi-tenant SaaS offering with a faster, largely automatic release cadence and more restricted customization).

How Access Is Protected

Access to S/4HANA is protected exactly the way described in the Security & Controls Introduction guide: users, roles, authorization objects, and the AUTHORITY-CHECK logic enforced on the application server for every action. What changes across deployment flavors is who can configure that protection and how directly. In On-Premise and Private Cloud editions, security teams still build and maintain roles largely the same way they always have (PFCG, classic authorization objects). In Public Cloud Edition, SAP restricts direct backend configuration access; role-building instead happens through a more standardized, pre-packaged business-role concept, and much of the underlying technical complexity is intentionally hidden from the customer to keep the system easy for SAP to upgrade on its automatic schedule.

What Controls It Enables / Needs

S/4HANA is the system where most classic ITGC and SOX testing still centers: user access reviews, segregation-of-duties analysis, sensitive/emergency access, and change management all ultimately point back to what is configured here. The deployment flavor changes some of the mechanics — for example, in Public Cloud Edition, testing SAP's own release process is largely replaced by relying on SAP's own compliance attestations (a topic revisited in Chapter 6) — but the underlying questions (who can do what, was it approved, is there a record) never change.

Chapter 3 — The SAP GRC Suite

Everything in the Security & Controls Introduction guide — access requests, segregation of duties, emergency access, periodic reviews, automated monitoring — can technically be done with spreadsheets and manual effort. SAP GRC (Governance, Risk, and Compliance) is the purpose-built software that automates and documents that work instead. “GRC” is not one tool; it is a suite of distinct modules, each covering a different piece of the story you already learned.

3.1 SAP GRC Access Control (GRC AC)

The module most controls professionals mean when they say “GRC” casually. It has four core capabilities, each mapping directly to a chapter you have already studied:

Capability	What It Does
Access Risk Analysis (ARA)	Runs the automated segregation-of-duties rule set against actual user and role assignments, producing the conflict reports referenced throughout the SoD chapter.
Access Request Management (ARM)	Digitizes and enforces the request-and-approval workflow — including automatic SoD warnings at the point of request — covered in the access-provisioning chapter.
Business Role Management (BRM)	Provides a standardized, governed methodology for designing and maintaining roles, reducing the chance of the hidden-permission and scope problems covered in the role-design chapter.
Emergency Access Management (EAM)	The system-based version of the break-glass key — issuing, logging, and routing for review every use of temporary elevated (“firefighter”) access.

3.2 SAP GRC Process Control (GRC PC)

Where Access Control governs who can do things, Process Control governs whether the business processes and system configurations themselves are behaving as designed. It maintains a repository of defined controls, automates testing and evidence collection on a schedule, and includes continuous control monitoring (CCM) — the automated “watchdog” capability referenced in the configuration-and-change-control chapter, which flags things like an out-of-hours configuration change the moment it happens.

3.3 SAP GRC Risk Management (GRC RM)

A broader enterprise risk register that sits above individual access or process controls — tracking business risks generally, linking them to the specific controls meant to mitigate them, and supporting risk heat-map style reporting for leadership. It is the least SAP-technical of the GRC modules and the most similar to a general enterprise risk platform.

3.4 SAP Audit Management

A module for running the audit function itself: planning engagements, building work programs, collecting workpapers and evidence, tracking findings, and following remediation plans through to closure — the same lifecycle covered in the controls-audit-process chapter, but with its own dedicated system of record instead of spreadsheets and email.

3.5 SAP Cloud Identity Access Governance (IAG)

As landscapes shift toward the cloud, SAP's cloud-native answer to GRC Access Control is IAG — covering the same core ground (access analysis, role design, access requests, and a Privileged Access Management capability that mirrors Emergency Access Management) but built to govern cloud applications like S/4HANA Cloud, SuccessFactors, and BTP directly, often working alongside (rather than instead of) an on-premise GRC AC system during a transition period.

WHY THIS MATTERS

Nearly every technique described generically in the Security & Controls Introduction guide — “you pull the conflict report,” “you check whether a mitigating control is on file,” “you compare the revoke decision to what's actually assigned” — describes exactly what these GRC modules are built to automate. Learning GRC is largely learning where the manual process you already understand now lives inside a dedicated tool.

Chapter 4 — SAP Fiori

What It Is

SAP Fiori is SAP's modern user experience layer — a tile-based launchpad, accessible from a browser or mobile device, that has largely replaced the classic SAP GUI screen as the default way people interact with SAP. It is not a separate system with its own data; it is a front end that calls the same underlying business logic on the application server described in the Foundations Primer. Fiori apps are organized into business catalogs (collections of related tiles/apps) and business groups (how those catalogs are arranged and labeled for a given user's launchpad).

How Access Is Protected

Fiori access is a two-layer story. The front-end layer controls which tiles a user sees, through catalogs and groups assigned via roles, much like a menu. The back-end layer is the real gatekeeper: each tile is wired, through a target mapping, to an actual underlying transaction or OData service (a structured data-access channel), and that underlying call is still subject to the exact same AUTHORITY-CHECK enforcement as any classic transaction. A tile can be hidden from a launchpad and the underlying access can still exist — which is precisely why Fiori-specific testing exists.

What Controls It Enables / Needs

Controls work around Fiori focuses on the gap between what a user sees and what a user can actually reach: catalogs that grant more than their label suggests, OData services left unrestricted behind a display-only-looking tile, target mappings wired to a more powerful screen than the tile implies, and launchpads that fall out of sync after a user's backend access is downgraded. Every one of these was covered as a named finding in the Security & Controls Introduction guide's Fiori chapter — this is simply the formal vocabulary behind that same set of risks.

Chapter 5 — SAP BTP (Business Technology Platform)

What It Is

SAP BTP is SAP's cloud platform for building extensions, integrating systems, and running analytics — the infrastructure layer that sits underneath much of modern SAP's cloud footprint. A BTP landscape is organized hierarchically: a global account (the overall commercial contract) contains one or more subaccounts (typically split by environment or purpose, such as development versus production), and subaccounts contain spaces or organizations where actual applications and services run. Common services built on BTP include SAP Integration Suite (connecting systems together), custom extension applications, SAP Analytics Cloud, and SAP Datasphere (data warehousing/virtualization).

How Access Is Protected

Two layers of access matter on BTP. First, platform-level access: who can administer a subaccount, deploy applications, view service credentials, or change entitlements (the quotas of services a subaccount is allowed to consume) — governed through role collections (bundles of roles, conceptually similar to a composite role) assigned in the BTP cockpit. Second, application-level access: once a custom or SAP-delivered application is running on BTP, it has its own end-user roles and scopes, which must be designed with the same rigor as any classic SAP role. Underpinning both is SAP Cloud Identity Services — specifically the Identity Authentication service (IAS), which acts as the trusted identity provider/single sign-on broker for BTP and increasingly for S/4HANA Cloud, SuccessFactors, and other cloud applications, and the Identity Provisioning service (IPS), which automates creating, updating, and removing user accounts across those connected systems from a single source.

What Controls It Enables / Needs

Because BTP and SAP Cloud Identity Services increasingly sit in the middle of the whole landscape — brokering logins and provisioning access into many other systems at once — they are a high-leverage control point: a misconfiguration here does not affect one system, it potentially affects every system trusting that identity provider. Controls work therefore focuses on subaccount/space administrative access (who can deploy or see secrets), entitlement governance (preventing uncontrolled cost/service sprawl), trust configuration between BTP and connected systems, and — critically — the accuracy and timeliness of the automated provisioning/deprovisioning flows running through Identity Provisioning, since a broken or misconfigured feed here can silently recreate the exact “terminated user still active” problem from Chapter 1 of the Security & Controls Introduction guide, just at cloud scale.

Chapter 6 — Cloud Security Fundamentals

Every cloud application in this guide — S/4HANA Public Cloud, BTP, SuccessFactors, and others — shares a set of security concepts that apply regardless of which specific product you are looking at. These are worth learning once, generically, rather than relearning per application.

6.1 The Shared Responsibility Model

In any cloud arrangement, security responsibility is split between the vendor and the customer, and knowing exactly where the line falls is the single most important cloud-security concept for a controls professional.

Responsibility	Who Owns It (Typical Cloud Model)
Physical data center security	SAP / Cloud Provider
Infrastructure patching, hypervisor security	SAP / Cloud Provider
Application-level patching and upgrades (Public Cloud editions)	SAP / Cloud Provider
Network perimeter of the cloud provider itself	SAP / Cloud Provider
Who gets a user account and what role they hold	Customer
Segregation of duties and sensitive access design	Customer
Custom extension code built on BTP	Customer
Data classification and business-level access decisions	Customer

This is why an auditor testing a cloud application relies partly on the vendor's own independent attestation: for the portion of the responsibility that belongs to SAP or the cloud provider, customers and their auditors typically rely on third-party attestation reports (commonly SOC 1 and SOC 2 reports) covering the provider's controls, rather than testing SAP's data centers directly. The customer-owned portion — access, roles, SoD, provisioning accuracy — is still tested directly, exactly as covered throughout this training series.

6.2 Core Cloud Security Controls Worth Recognizing by Name

Concept	What It Means
Multi-Factor Authentication (MFA)	Requiring a second proof of identity beyond a password — now close to a baseline expectation for any cloud login, especially privileged access.
Single Sign-On (SSO)	Authenticating once with a trusted identity provider and being trusted automatically across every connected system, rather than maintaining separate passwords everywhere.
Conditional Access	Rules that adjust login requirements based on context — for example, requiring extra verification for a login from an unrecognized location or device.

Concept	What It Means
Encryption in Transit / at Rest	Data is unreadable if intercepted while moving between systems, and unreadable if the underlying storage itself were ever accessed directly.
Data Residency	Contractual and technical commitments about which physical region a customer's data is stored and processed in — often relevant for regulatory reasons beyond SOX.
Subprocessor / Vendor Risk Management	Understanding and monitoring which additional third parties a cloud vendor itself relies on, since their risk becomes an indirect part of the customer's own risk.

Chapter 7 — The Rest of the Ecosystem

Beyond the core applications already covered, a real engagement regularly touches a wider ring of SAP and non-SAP tools. You do not need deep expertise in any of these to start — you need to recognize each by name and know, in one sentence, why it might matter to a controls engagement.

7.1 Other SAP Applications

Application	Why It Matters for Controls
SAP Solution Manager / Focused Run	Technical monitoring plus Change Request Management (ChaRM) — the governed pipeline that approves and tracks changes moving toward production, directly relevant to change-management testing.
SAP Business Application Studio	A cloud-based development environment for building extensions on BTP; developer access here carries the same code-change risk as classic ABAP development access.
SAP SuccessFactors	SAP's cloud HR suite; frequently the authoritative source of joiner/mover/leaver events that trigger access provisioning and deprovisioning across the rest of the landscape.
SAP Ariba	Cloud procurement/sourcing suite; often in SOX scope directly because of its role in vendor management and purchase-to-pay processes.
SAP Concur	Cloud travel and expense management; frequently in SOX scope for expense-reimbursement and corporate card controls.
SAP Analytics Cloud / SAP Datasphere	Reporting, planning, and data-warehousing layer; carries its own access model and is increasingly where sensitive combined data from multiple systems is exposed in one place.

7.2 Frequently Encountered Third-Party Tools

Tool Category	Why It Matters for Controls
External Identity Providers (Microsoft Entra ID / Azure AD, Okta)	Many organizations federate SAP's own identity services to a company-wide identity

Tool Category	Why It Matters for Controls
	provider, meaning the true “source of truth” for authentication may live outside SAP entirely.
ITSM / Ticketing Platforms (e.g., ServiceNow)	Often the actual system of record for access requests and change approvals, integrated with (or feeding evidence into) SAP GRC or Solution Manager.
Specialized SAP Security & GRC Tools (e.g., Pathlock, SecurityBridge, Onapsis, Xiting XAMS)	Third-party alternatives or supplements to SAP's own GRC and security monitoring capabilities, sometimes chosen for deeper technical vulnerability scanning or a different licensing model.
Enterprise GRC Platforms (e.g., Archer, MetricStream)	Company-wide risk and controls systems that may sit above SAP GRC entirely, aggregating SAP-specific findings alongside risk from every other part of the business.
A NOTE ON SCOPE You are not expected to become an expert in every tool listed here before your first engagement. The goal of this chapter is recognition: when a client mentions one of these names in a kickoff meeting, you should be able to place it correctly on the map from Chapter 1 without it derailing your understanding of the rest of the conversation.	

Chapter 8 — How It All Fits Together

Here is the whole landscape, told as one continuous story, tying every application in this guide to a single, realistic sequence of events.

#	Event	What Happens, and Where
1	A new employee is hired	The event originates in SAP SuccessFactors (or another HR system), which is the authoritative record of who has joined, moved, or left.

#	Event	What Happens, and Where
2	An identity is created and access is requested	SAP Cloud Identity Services (Identity Provisioning) can automatically create the underlying user identity; a request for specific business access is raised and routed through SAP GRC Access Control (or Cloud IAG) Access Request Management, including an automatic segregation-of-duties check.
3	Access is approved and provisioned	Once approved, roles are assigned in the target system — SAP S/4HANA (on-premise, private cloud, or public cloud), built using Business Role Management's governed methodology.
4	The user logs in and works	Authentication is brokered through SAP Cloud Identity Services (Identity Authentication) via single sign-on; the user's daily work happens through SAP Fiori tiles, which call the same authorization-checked business logic on S/4HANA's application server described in the Foundations Primer.
5	The system and its controls are continuously watched	SAP GRC Process Control runs scheduled and continuous monitoring against configuration and control settings; Solution Manager/Focused Run governs any changes moving through the transport pipeline via ChaRM.
6	Periodic reviews and emergency	Access Risk Analysis and periodic access certification campaigns

#	Event	What Happens, and Where
	access are managed	run through GRC Access Control; any emergency access is checked out and logged through Emergency Access Management.
7	An issue is found and tracked to closure	Findings are documented and tracked through SAP Audit Management or GRC Risk Management, with remediation plans assigned an owner and a deadline.
8	The cloud portion of all of the above is itself governed	For every cloud application in this chain, the shared responsibility model applies — SAP's own SOC 1/SOC 2 attestations cover the infrastructure layer, while every access, role, and provisioning decision above that line remains the customer's (and this training's) direct responsibility.
THE THROUGH-LINE Notice that every single step in this chain is something you have already learned the logic of, in the Security & Controls Introduction guide — provisioning, authorization checks, monitoring, remediation. This chapter has not taught you anything conceptually new. It has told you which named application, in a real landscape, is responsible for each step you already understand.		

Chapter 9 — Glossary of Terms

Term	Plain-English Meaning
Business Catalog / Group	The Fiori-side grouping of tiles/apps assigned to a user's launchpad.
ChaRM (Change Request Management)	Solution Manager/Focused Run's governed pipeline for approving and tracking changes toward production.
Cloud IAG	SAP Cloud Identity Access Governance — the cloud-native counterpart to GRC Access Control.

Term	Plain-English Meaning
Continuous Control Monitoring (CCM)	GRC Process Control's capability to automatically watch configuration/control settings and flag deviations as they happen.
Entitlement (BTP)	The quota of a given service a BTP subaccount is permitted to consume.
GRC (Governance, Risk, and Compliance)	SAP's suite of dedicated modules for managing access risk, process controls, enterprise risk, and audit.
Identity Authentication (IAS)	The SAP Cloud Identity Services component acting as identity provider / SSO broker.
Identity Provisioning (IPS)	The SAP Cloud Identity Services component that automates account creation/updates/removal across connected systems.
OData Service	A structured, standardized channel through which Fiori apps (and other clients) request or submit data to the backend.
Role Collection (BTP)	A bundle of BTP roles assigned to a platform or application user — conceptually similar to a composite role.
Shared Responsibility Model	The division of security ownership between a cloud vendor (infrastructure) and the customer (access, configuration, data).
SOC 1 / SOC 2 Report	Independent third-party attestation reports commonly relied upon as evidence for the vendor-owned portion of cloud controls.
Subaccount / Space (BTP)	The organizational units beneath a BTP global account where services and applications actually run.
Target Mapping	The Fiori configuration record connecting a visible tile to the actual backend transaction or service it launches.

Chapter 10 — Pre-Course Readiness Checklist

Before your first live session covering this application landscape, confirm you can do each of the following.

- I can name at least six applications in a typical SAP controls landscape and place each one on the map from Chapter 1.
- I can explain the difference between S/4HANA On-Premise, Private Cloud, and Public Cloud editions in one sentence each.
- I can name the four core capabilities of SAP GRC Access Control and match each to a concept from the Security & Controls Introduction guide.
- I can explain the difference between GRC Access Control, Process Control, Risk Management, and Audit Management.
- I can explain, in plain language, why a Fiori tile's label is not proof of what it actually grants access to.
- I can describe what SAP BTP is and name its two identity services and what each one does.

- I can explain the shared responsibility model and give one example of a customer-owned control and one example of a vendor-owned control.
- I can name at least three non-SAP tools I might encounter on a real engagement and explain in one sentence why each matters.
- I can walk through the end-to-end story in Chapter 8 from memory, naming which application handles each step.

READY TO BEGIN

Once every box above is checked honestly, you have both the conceptual grounding from the earlier guides in this series and the application-level map this course track assumes. Proceed to your live SAP Controls, Auditing, and SOX/ITGC coursework.